

SOC 2 Control Mapping to AWS Cloud Environment — TaskForge

A self-directed GRC project mapping SOC 2 Common Criteria (CC1–CC9) to specific AWS cloud configurations, demonstrating the technical fluency that lets a GRC analyst work directly with engineering teams rather than relying solely on policy-level documentation.

Current Status: Illustrative / Not Yet Executed on a Live Environment

This project was built as a **Control Implementation Guide** rather than a completed audit evidence package. I do not currently have an active AWS account, so the AWS console images in this guide are **illustrative mockups**, clearly labeled as such throughout the document — not real screenshots. The guide documents exactly what I would configure and capture once I have environment access, so it can be completed with real evidence without rewriting any of the underlying analysis.

This distinction matters and is something I want to be upfront about: the value of this project is in the control mapping and technical reasoning, not in a fabricated claim of hands-on execution I haven't yet performed.

Project Summary

This project maps five common AWS technical configurations to specific SOC 2 Common Criteria for **TaskForge**, a fictional project management SaaS application hosted on AWS. Rather than treating SOC 2 compliance as a policy-only exercise, the project demonstrates the technical side of GRC work: translating an abstract AICPA criterion into an exact, verifiable cloud configuration.

1. **AICPA criteria reference** — summarizing all nine Common Criteria series (CC1–CC9) from official AICPA-aligned sources
2. **Control-to-configuration mapping** — mapping MFA, S3 encryption, CloudTrail logging, IAM least-privilege policies, and automated backups to their specific SOC 2 criteria (concentrated in CC6 and CC7, the most evidence-intensive series)
3. **Step-by-step implementation guide** — exact AWS console steps for each control, written to be executed by a future version of this project once environment access exists
4. **Illustrative evidence mockups** — AWS console illustrations clearly labeled as mockups, showing what completed evidence should look like
5. **Summary control matrix** — a clean, audit-style table tying each control to its SOC 2 criteria, AWS implementation, and expected evidence type

Deliverables

File	Description
TaskForge_SOC2_AWS_Control_Guide.docx / .pdf	Full guide: AICPA CC1–CC9 reference, 5 control implementations with illustrative mockups, summary control matrix, and evidence collection notes

What I Did

- Researched the AICPA SOC 2 Common Criteria structure (CC1–CC9, including how many specific criteria fall under each series) from current public sources rather than relying on memory
- Selected five technical AWS configurations explicitly named in the project brief (MFA, S3 encryption, CloudTrail, IAM policies, backups) and mapped each to the specific CC criteria it satisfies, rather than vaguely gesturing at “security”
- Identified that all five configurations cluster into CC6 (Logical and Physical Access Controls) and CC7 (System Operations) — and explained *why*, rather than treating that pattern as a coincidence
- Wrote exact, executable AWS console steps for each control (specific menu paths, specific settings to enable, specific verification steps) so this guide is immediately actionable once I have environment access
- Built illustrative AWS console mockups for all five controls, deliberately and clearly labeled as mockups rather than real screenshots, including realistic technical details (e.g., scoped IAM policy JSON, a CloudTrail event log showing the other four controls being configured)
- Connected this project back to two earlier projects in this portfolio: the S3 public-bucket risk identified in the BudgetWise risk register, and the backup-testing lesson from the Meridian incident response plan — showing the portfolio’s projects build on each other rather than existing in isolation
- Wrote evidence collection notes explaining the difference between SOC 2 Type I (design) and Type II (operating effectiveness over time) evidence requirements, since a single screenshot only ever proves the former

What I Learned

- **Most hands-on cloud security work concentrates in two SOC 2 criteria.** CC6 and CC7 cover access control and system operations respectively, and that’s where nearly all console-level technical work lives. CC1–CC5 and CC8–CC9 are real and important, but they’re demonstrated through policy, process, and governance documentation, not button-clicks — a distinction that matters when explaining to an engineer *why* a particular control matters to an audit.
- **A control mapping is only useful if it’s specific.** “This relates to access control” is not a mapping. “This satisfies CC6.3, which requires authorizing access based on job function” is a mapping an auditor could actually test against.
- **Evidence has a shelf life.** A SOC 2 Type II report requires proof that a control operated effectively over 6–12 months, not just that it was configured once. A single screenshot is necessary but not sufficient — this reframed how I think about “evidence” as something that needs a collection cadence, not a one-time capture.
- **Honesty about gaps is itself a GRC skill.** Recognizing that I couldn’t ethically present mockups as real audit evidence — and choosing instead to clearly label them and build a guide for future real execution — mirrors exactly the kind of integrity a GRC analyst is expected to bring to actual audit evidence collection, where overstating control maturity is a real and serious professional risk.

- **Technical specificity is the actual differentiator GRC analysts bring to engineering conversations.** Being able to say “the app role needs `s3:GetObject` and `s3:PutObject` scoped to one bucket ARN, not `AdministratorAccess`” is a fundamentally different (and more credible) conversation with an engineering team than citing a policy document at them.

Real-World Application

This kind of technical control mapping is a genuine, high-value differentiator for GRC analysts working alongside engineering and DevOps teams:

- **Audit evidence collection** — SOC 2 auditors request specific, named evidence (e.g., “show me your IAM policies,” “show me CloudTrail is enabled”); knowing exactly what artifact satisfies which criterion before the auditor asks saves real time during an audit cycle
- **Engineering collaboration** — GRC analysts who can speak in terms of specific AWS services and IAM policy syntax, rather than only policy language, are taken far more seriously by engineering teams and can identify gaps engineers themselves may not realize map to compliance requirements
- **Pre-audit readiness assessments** — this kind of control-by-control mapping is exactly what a readiness assessment produces before a company pursues its first SOC 2 report, identifying gaps while there’s still time to remediate them
- **Vendor and customer assurance** — being able to explain *how* a specific control is technically implemented (not just that a policy exists) is often what satisfies a sophisticated enterprise customer’s security questionnaire, directly connecting to the vendor assessment skills from this portfolio’s Slack project

Conclusion

This project demonstrates a distinct, technical fifth pillar of GRC analyst work: the ability to translate an abstract compliance criterion into a specific, verifiable cloud configuration, and to speak credibly with the engineers who actually implement it. It is also the project in this portfolio most directly limited by real-world constraints — without AWS environment access, the honest scope of this work is a control implementation guide, not a completed audit evidence package, and I’ve tried to be transparent about exactly where that line sits rather than blur it. Completing this project’s full intent (real screenshots, real verification) remains a clear, well-defined next step once environment access exists, and the guide built here means that final step is mechanical, not analytical — the actual GRC reasoning is already done.

This is a self-directed portfolio project using a fictional organization. AWS console images are illustrative mockups, not screenshots from a live AWS environment.

SOC 2 Control Implementation Guide

Mapping AWS Cloud Configuration to SOC 2 Common Criteria (CC1–CC9)

TaskForge (Project Management SaaS) | Prepared by Kevin Liao

Note on this document: AWS console images in this guide are illustrative mockups, not screenshots from a live AWS account. This guide is written as a Control Implementation Guide — the exact steps and evidence an analyst would execute and capture once granted environment access. Each section can be completed and re-evidenced with real screenshots when a live AWS environment is available.

1. AICPA SOC 2 Common Criteria Reference

SOC 2 Common Criteria (CC1–CC9) form the mandatory Security baseline of every SOC 2 audit, regardless of which additional Trust Services Categories (Availability, Confidentiality, Processing Integrity, Privacy) are in scope. The nine series are summarized below.

Series	Name	Focus
CC1	Control Environment	Organizational integrity, ethics, roles, and responsibilities supporting a security culture
CC2	Communication & Information	Security policies and expectations are communicated clearly to internal and external parties
CC3	Risk Assessment	The organization identifies and analyzes risks to its objectives
CC4	Monitoring Activities	Ongoing evaluation of whether controls are present and functioning
CC5	Control Activities	Policies and procedures translated into action (e.g., access procedures, change approvals)
CC6	Logical & Physical Access Controls	Restricting system/data access to authorized individuals — the broadest CC criterion, covering authentication, encryption, and key management
CC7	System Operations	Detecting, monitoring, and responding to security events; incident response and recovery
CC8	Change Management	Changes to system components are tested and approved through a controlled process
CC9	Risk Mitigation	Mitigating risk through business processes and vendor/business-partner management

2. Control-by-Control Implementation

TaskForge is a project management SaaS application hosted entirely on AWS. The five technical configurations below were selected because they represent the most heavily evidenced controls in a typical SOC 2 audit, concentrated in CC6 (Logical and Physical Access Controls) and CC7 (System Operations) — consistent with CC6 being the broadest Common Criteria series.

2.1 Multi-Factor Authentication (MFA)

SOC 2 Mapping: CC6.1 (restrict logical access — authentication) | CC6.2 (credential management)

MFA strengthens authentication beyond a password alone, directly satisfying CC6's expectation that the entity implements logical access security commensurate with the sensitivity of the data protected.

Implementation: enable MFA on the AWS root user immediately upon account creation, then require MFA for all IAM users with console access. Service/programmatic accounts (e.g., application deployment roles) are excluded from interactive MFA by design, since they do not authenticate via a human-facing login — this distinction matters because incorrectly expecting MFA on service accounts is a common audit misunderstanding.

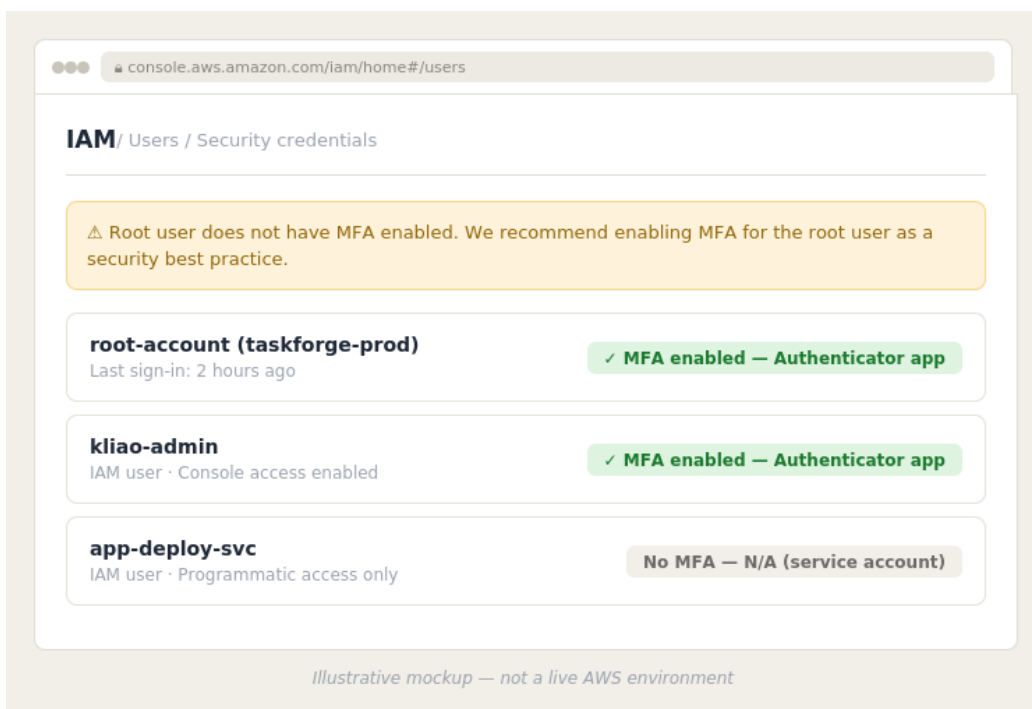


Figure 1 — IAM console showing MFA status across root and IAM users (illustrative)

2.2 S3 Bucket Encryption

SOC 2 Mapping: CC6.1 (encryption and key management) | CC6.7 (restricting data movement to authorized means)

Default encryption at rest protects stored data even if a storage-level access control is somehow bypassed, satisfying CC6.1's encryption point of focus. Implementation: enable default encryption (SSE-S3 or SSE-KMS) on every S3 bucket at creation time, enable versioning to support recovery from accidental overwrite or deletion, and enable Block Public Access at the bucket level to prevent accidental public exposure — directly mitigating the misconfigured-bucket risk pattern identified in the BudgetWise risk register project (Risk R1).

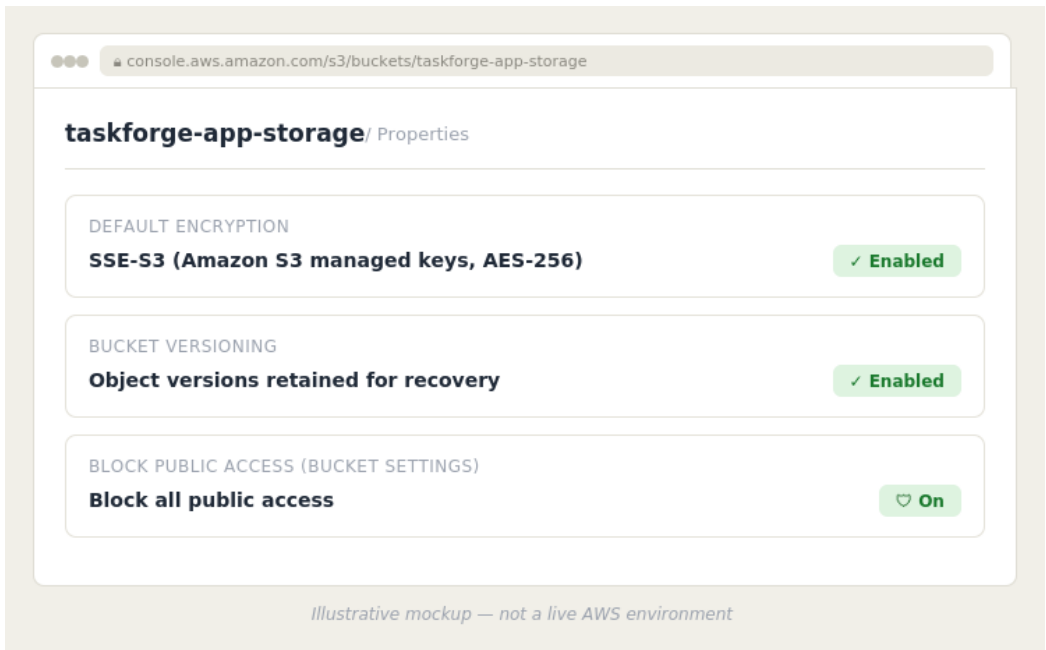


Figure 2 — S3 bucket Properties tab showing encryption, versioning, and public access block (illustrative)

2.3 CloudTrail Logging

SOC 2 Mapping: CC7.1 (detecting and monitoring security events) | CC7.2 (identifying and analyzing anomalies)

CloudTrail provides the account activity record that makes CC7's monitoring expectations achievable — it is typically the single most-requested piece of evidence in a SOC 2 audit, since it demonstrates that activity across the environment is being captured, not just that policies exist on paper. Implementation: create an organization-wide trail applying to all regions, enable log file validation (so logs cannot be silently altered without detection), and route logs to both S3 (long-term retention) and CloudWatch Logs (real-time monitoring/alerting).

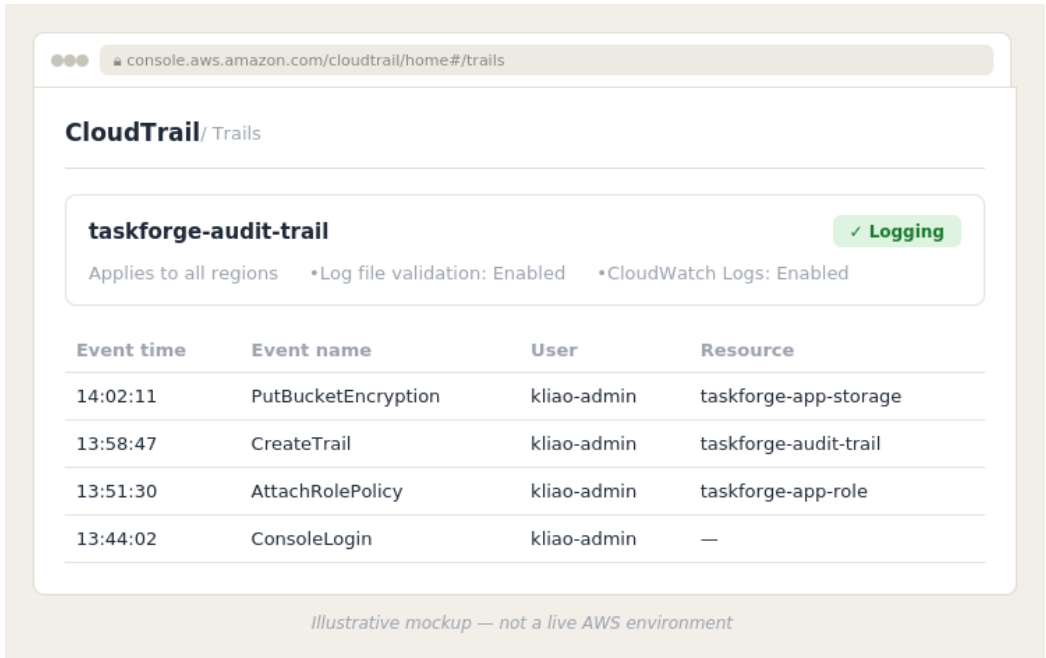


Figure 3 — CloudTrail trail configuration and event history (illustrative)

2.4 IAM Role Policies (Least Privilege)

SOC 2 Mapping: CC6.1 (restrict logical access) | CC6.3 (authorize access based on job function/role)

Scoped IAM policies are the clearest technical evidence that access is authorized based on need, not granted broadly by default. Implementation: avoid attaching AdministratorAccess to any role or user except in narrow, justified break-glass scenarios; instead, write scoped policies naming specific actions (e.g., s3:GetObject, s3:PutObject) restricted to specific resource ARNs. Application/service roles should never receive broader permissions than the specific AWS APIs the application code actually calls.

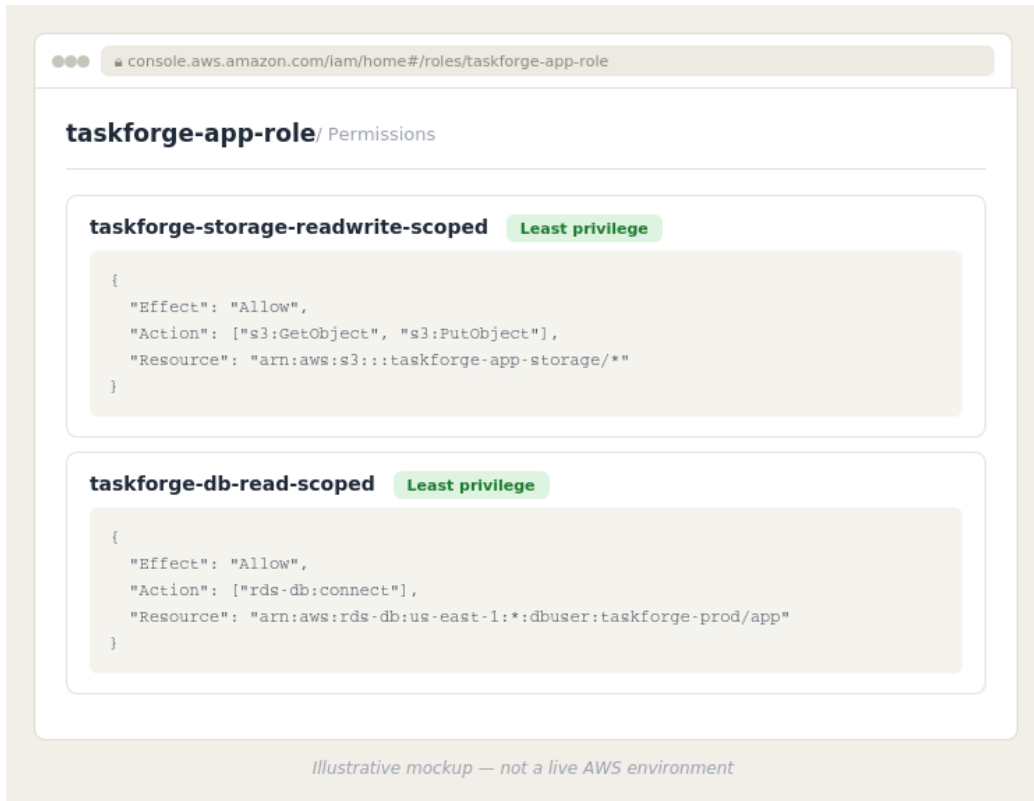


Figure 4 — IAM role showing scoped least-privilege policy JSON (illustrative)

2.5 Automated Backups

SOC 2 Mapping: CC7.5 (recovery from identified security incidents/disruptions) | CC9.1 (mitigating risk from business disruption)

Automated, verified backups are the technical foundation behind any business continuity claim in a SOC 2 report. Implementation: enable automated backups on the production RDS database with a defined retention period (e.g., 7 days), and enable S3 versioning for object-level recovery. Consistent with the lesson from the Meridian Electronics incident response project, backup existence alone is insufficient evidence — a complete control narrative should also reference periodic restoration testing, even though that activity is procedural rather than a one-time console setting.

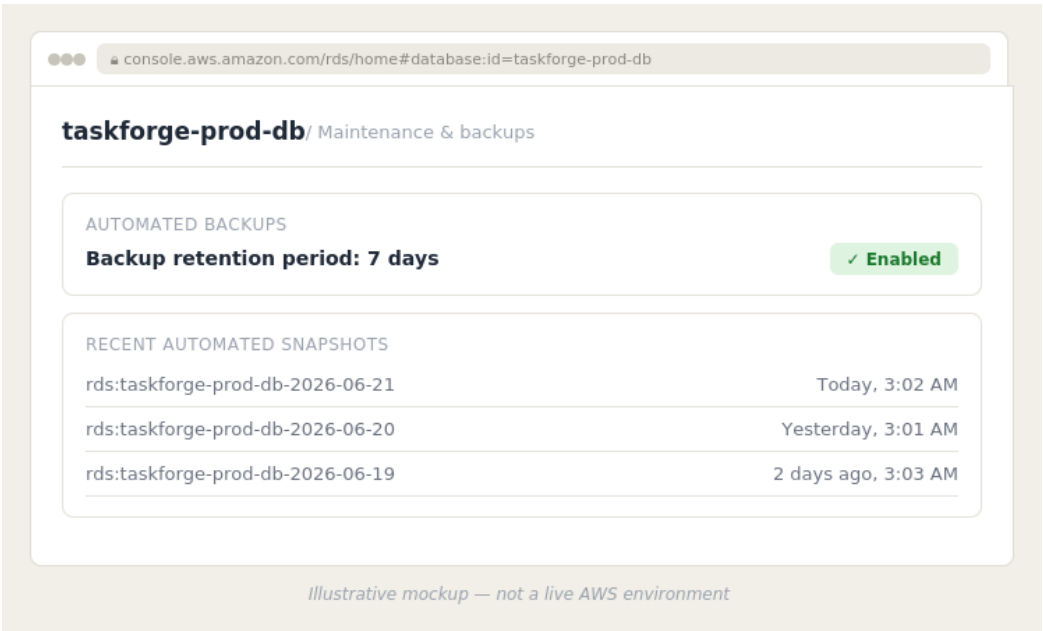


Figure 5 — RDS Maintenance & Backups tab showing automated backup retention and recent snapshots (illustrative)

3. Summary Control Matrix

Control	SOC 2 Criteria	AWS Implementation	Evidence Type
Multi-Factor Authentication	CC6.1, CC6.2	MFA enforced on root and all IAM console users	IAM console screenshot
S3 Encryption	CC6.1, CC6.7	Default encryption (SSE-S3/KMS) + versioning + public access block	S3 Properties screenshot
CloudTrail Logging	CC7.1, CC7.2	All-region trail with log file validation and CloudWatch integration	CloudTrail console screenshot
IAM Least Privilege	CC6.1, CC6.3	Scoped custom policies, no broad AdministratorAccess on app roles	IAM policy JSON screenshot
Automated Backups	CC7.5, CC9.1	RDS automated backups (7-day retention) + S3 versioning	RDS console screenshot

4. Evidence Collection Notes

Per the project's evidence collection requirement, each control's screenshot should be stored as a dated artifact (e.g., 'SOC2_CC6.1_MFA_2026-06-21.png') in a dedicated evidence folder, separate from this guide. Real SOC 2 Type II audits require evidence that controls operated effectively over an observation period (typically 6–12 months) — meaning a single point-in-time screenshot demonstrates design, but recurring evidence (e.g., monthly screenshots, or automated evidence collection via a GRC platform) is required to demonstrate operating effectiveness. This guide documents control design; an operating-effectiveness evidence cadence would be the next step once a live environment exists.